Análisis de Ciberseguridad — Sistema de Control Industrial

Planta de Tratamiento de Aguas — Zona Metropolitana

1. Identificación del Error en la Arquitectura

El componente crítico con una configuración e interconexión incorrecta es la **HMI Workstation**, que ejecuta el software WinCC SCADA sobre un sistema operativo obsoleto (Windows 7) y posee **TeamViewer habilitado**. El error principal de diseño radica en su ubicación física y lógica dentro de la **Zona Corporativa (Red IT)**, manteniendo al mismo tiempo una conexión directa hacia el SWITCH-OT en la **Zona OT — Red de Control Industrial**. Esta disposición rompe el principio fundamental de segmentación de redes industriales.

2. Vector de Ataque Habilitado

Esta deficiencia de diseño habilita un vector de ataque por **Acceso Remoto No Autorizado / Salto de Red (Network Pivot)**. La exposición de un software de control remoto comercial como TeamViewer en la red IT corporativa (la cual está conectada a Internet mediante el firewall perimetral) permite que un atacante externo, tras comprometer las credenciales corporativas o explotar una vulnerabilidad en la estación de trabajo, salte directamente a la red de control industrial saltándose los controles perimetrales. Este vector está ampliamente definido y clasificado en marcos regulatorios e internacionales como la **Guía de Seguridad en Sistemas de Control Industrial (NIST SP 800-82)** y el estándar **ISA/IEC 62443**.

3. Principio AIC Vulnerado

El principio de la tríada AIC comprometido de manera primaria es la **Integridad**. Al tomar control de la HMI a través de la sesión de acceso remoto, un atacante adquiere la capacidad de enviar comandos arbitrarios al SWITCH-OT y, por consiguiente, al PLC PRINCIPAL (Siemens S7-315). Esto le permitiría modificar los parámetros de operación (setpoints), alterar la lógica de control de las bombas y válvulas, o manipular las dosificaciones de cloro. Se vulnera la integridad del proceso industrial de forma directa, provocando un impacto potencialmente catastrófico en la calidad del agua antes de que se vea afectada la disponibilidad de la planta.

4. Contramedida Técnica Recomendada

La solución definitiva para mitigar este riesgo estructural consiste en la implementación de una **DMZ Industrial (Zona Desmilitarizada)** y la reubicación de la HMI Workstation a la Zona OT de manera aislada. La función técnica de la DMZ Industrial es actuar como una subred intermedia que segmenta estrictamente la Red IT de la Red OT, impidiendo todo tráfico directo entre ambas. Todo flujo de datos o acceso requerido desde el exterior o la red corporativa debe finalizar en la DMZ y ser inspeccionado por un firewall industrial. Adicionalmente, se debe

eliminar por completo el uso de TeamViewer en la HMI, sustituyéndolo por una **Puerta de Enlace de Acceso Remoto Seguro (Secure Remote Access Gateway)** basada en la DMZ, con políticas estrictas de Autenticación Multi-Factor (MFA) y túneles VPN cifrados y auditados.